

Architettura di Identity Management

Introduzione ad Active Directory Domain Services (AD DS)



Introduzione ad Active Directory Domain Services (AD DS)

- **Definizione:** Servizio di directory gerarchico per la gestione centralizzata di identità, risorse e criteri di sicurezza.
- **Componenti Logiche:**
 - **Foresta:** Il confine di sicurezza più esterno che raggruppa uno o più domini.
 - **Dominio:** Unità amministrativa per la gestione di utenti e computer.
 - **Organizational Units (OU):** Contenitori utilizzati per organizzare gli oggetti e applicare Group Policy (GPO).
- **Ruolo del Domain Controller (DC):** Server responsabile dell'autenticazione (Identity Provider) e dell'autorizzazione all'interno del dominio.



Protocolli di Autenticazione e Risoluzione

Meccanismi di comunicazione in ambiente Windows

Kerberos (Default)

Protocollo di autenticazione basato su ticket (TGT/ST). Garantisce mutua autenticazione tra client e server.

NTLM (NT LAN Manager)

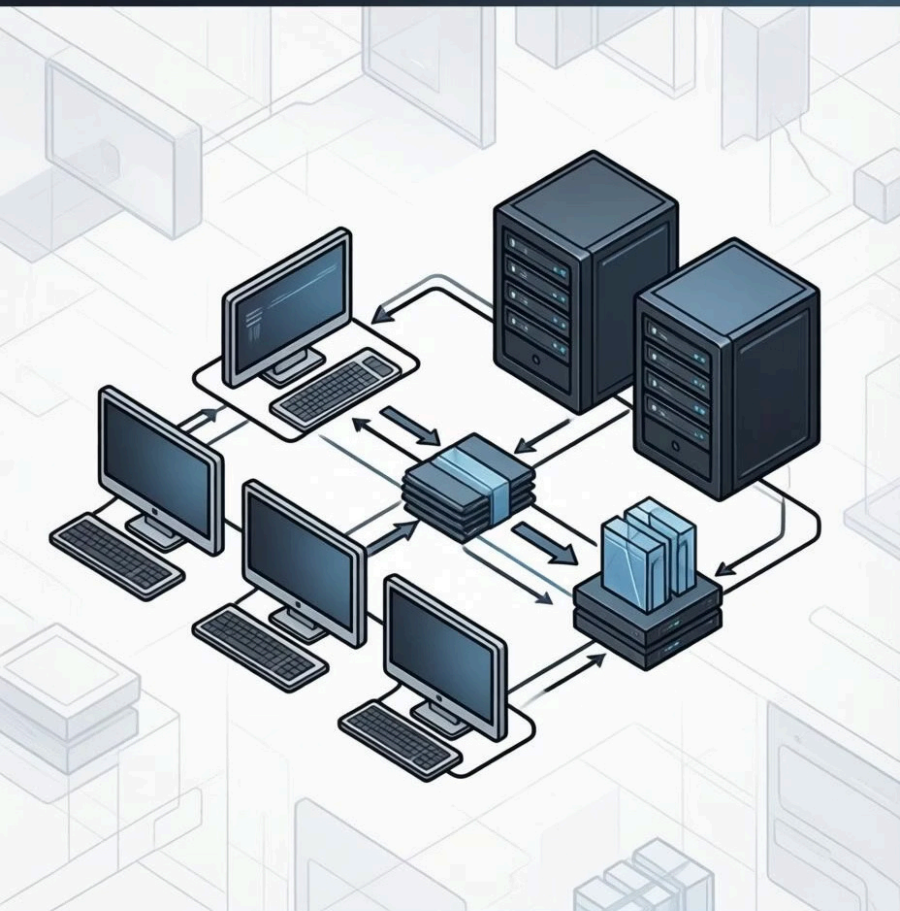
Protocollo legacy basato su challenge/response, mantenuto per compatibilità ma intrinsecamente meno sicuro.

LDAP/s

Protocollo per l'interrogazione del database di Active Directory.

DNS

Fondamentale per il service discovery (localizzazione dei DC tramite record SRV).



Analisi di NetBIOS over TCP/IP (NBT)

Caratteristiche e Funzionamento

- **Scopo:** Fornire servizi per la comunicazione di applicazioni legacy su reti TCP/IP.
- **Servizi Principali:**
 - **Name Service (UDP 137):** Risoluzione dei nomi host in indirizzi IP in assenza di DNS.
 - **Datagram Service (UDP 138):** Trasferimento dati connectionless.
 - **Session Service (TCP 139):** Comunicazione orientata alla connessione (utilizzata da versioni datate di SMB).
- **Limitazioni:** Protocollo non instradabile (limitato al segmento di rete locale) e privo di meccanismi di sicurezza moderni.

Vettori di Attacco e Superficie di Esposizione

Criticità in Active Directory

Privilege Escalation

Sfruttamento di configurazioni errate per elevare i privilegi da utente standard a Domain Admin.

Lateral Movement

Capacità di un attaccante di spostarsi tra le workstation dopo aver compromesso una singola identità.

Persistence

Creazione di backdoor silenti (es. utenti nascosti o modifiche alle ACL) per mantenere l'accesso a lungo termine.

Vulnerabilità dei Protocolli Legacy

Rischi associati a NetBIOS e LLMNR

- **Name Resolution Poisoning:** Gli attaccanti possono rispondere alle richieste NetBIOS/LLMNR broadcast non soddisfatte dal DNS, intercettando l'hash della password dell'utente (es. tramite attacchi Man-in-the-Middle).
- **Enumerazione degli Utenti:** NetBIOS può permettere a un utente non autenticato di enumerare nomi utente, gruppi e condivisioni di rete tramite sessioni nulle (*Null Sessions*).
- **Smuting/Relay Attacks:** Utilizzo degli hash intercettati per autenticarsi su altri sistemi della rete senza conoscere la password in chiaro.

Strategie di Mitigazione e Hardening

Protezione dell'infrastruttura di identità

Disabilitazione Protocolli Insecuri

Disattivazione di NetBIOS over TCP/IP e LLMNR tramite Group Policy Objects (GPO) se l'infrastruttura DNS è integra.

Implementazione del Modello Tiered

Separazione netta dei privilegi per impedire che credenziali amministrative vengano esposte su workstation vulnerabili.

SMB Signing

Obbligo di firma digitale per il traffico SMB per prevenire attacchi di relay.

Monitoraggio Event ID

Analisi dei log di sicurezza per rilevare anomalie (es. Event ID 4624 per login sospetti o 4720 per creazione utenti).

